

Enhancing Retrieval Quality in RAG-Based Defensive Security Systems through Query Reformulation

Agentic AI Project Presentation

International Institute of Information Technology, Naya Raipur, Chhattisgarh

RAG + Query Reformulation + Security Intelligence

Subhodeep Sarkar - 253000118 (M.Tech CSE)

Nitish Kumar Bind - 253000112 (M.Tech CSE)

1. Introduction and Motivation

Defensive security tools such as IDS, anomaly detection platforms, and log-analysis systems depend on retrieving the right evidence from large knowledge bases.

In RAG systems, a weak or vague user query often leads to irrelevant retrieval and poor final answers.

Security users commonly ask symptom-based questions like 'something weird in my network traffic' rather than exact technique names.

Our project studies whether rewriting a query before retrieval can improve answer quality in cybersecurity use cases.

Core Problem

Query-document mismatch: human language is vague, while the corpus uses precise security terminology.

Research Question

Does query reformulation using LLM-based agents improve retrieval relevance and final answer quality in defensive security RAG systems?

2. What We Built

Step 1

Collected a defensive security corpus from MITRE ATT&CK, NVD CVEs, and CISA KEV.

Step 2

Chunked and embedded documents into a local Chroma vector database.

Step 3

Built a baseline RAG pipeline with retrieval plus grounded answer generation.

Step 4

Added four query reformulation agents to test smarter retrieval.

Step 5

Benchmarked all pipelines on 15 security queries.



Everything was run locally with Ollama, so no cloud API key was required.

3. Software and Tools Used

LLM

Llama 3.2 via Ollama

Used for query reformulation and final answer generation.

Embeddings

omic-embed-text via Ollama

Used to convert queries and chunks into vectors.

Vector DB

ChromaDB

Persistent local store for semantic retrieval.

Framework

LangChain + Python

Orchestration, ingestion, retrieval, and benchmarking.

Data sources: MITRE ATT&CK, NVD CVE feed, CISA KEV catalog

Evaluation artifacts: test_queries.json, results.csv, live demo screenshots

Local scripts used: ingest.py, benchmark.py, query.py, demo.py

Output artifacts: IEEE research paper PDF/DOCX and this presentation deck

Our Prompt

“Something is weird in my network?”

ENHANCED [STEPBACK]

Reformulated: "What types of cyberattacks involve holding data hostage to extort money from victims?"

Answer:

The MITRE ATT&CK techniques used in ransomware attacks include:

1. T1486 – Data Encrypted for Impact
2. TA0010 – Exfiltration
3. T1219 – Remote Access Tools

These techniques are mentioned in the provided context as being used by adversaries in ransomware attacks to extort victims and render data permanently inaccessible.

Recall@5=0.75 = MRR=1.00 Faithfulness=1.00

4. The Five Pipelines

Baseline

Uses the raw query exactly as typed.
This is the control pipeline.

Expansion

Adds cybersecurity wording and domain-specific terminology to a vague query.

HyDE

Creates a hypothetical answer paragraph first and retrieves using that text.

Step-Back

Generalizes a narrow question into a broader conceptual security query.

Decomposition

Breaks a complex query into smaller sub-queries and merges the evidence.

Idea: different queries need different reformulation behavior. The project compares which strategy works best.

5. Dataset and Evaluation

15

Total Queries

8

Vague Queries

7

Specific Queries

5

Pipelines

Top-5

Retrieval Depth

Recall@5: did the retriever bring relevant security documents into the top-5?

MRR: how early did the first relevant result appear?

Answer Overlap: how close was the generated answer to the prepared reference answer?

Faithfulness: was the answer grounded in retrieved evidence rather than pure model memory?

Example Query Types

Vague:

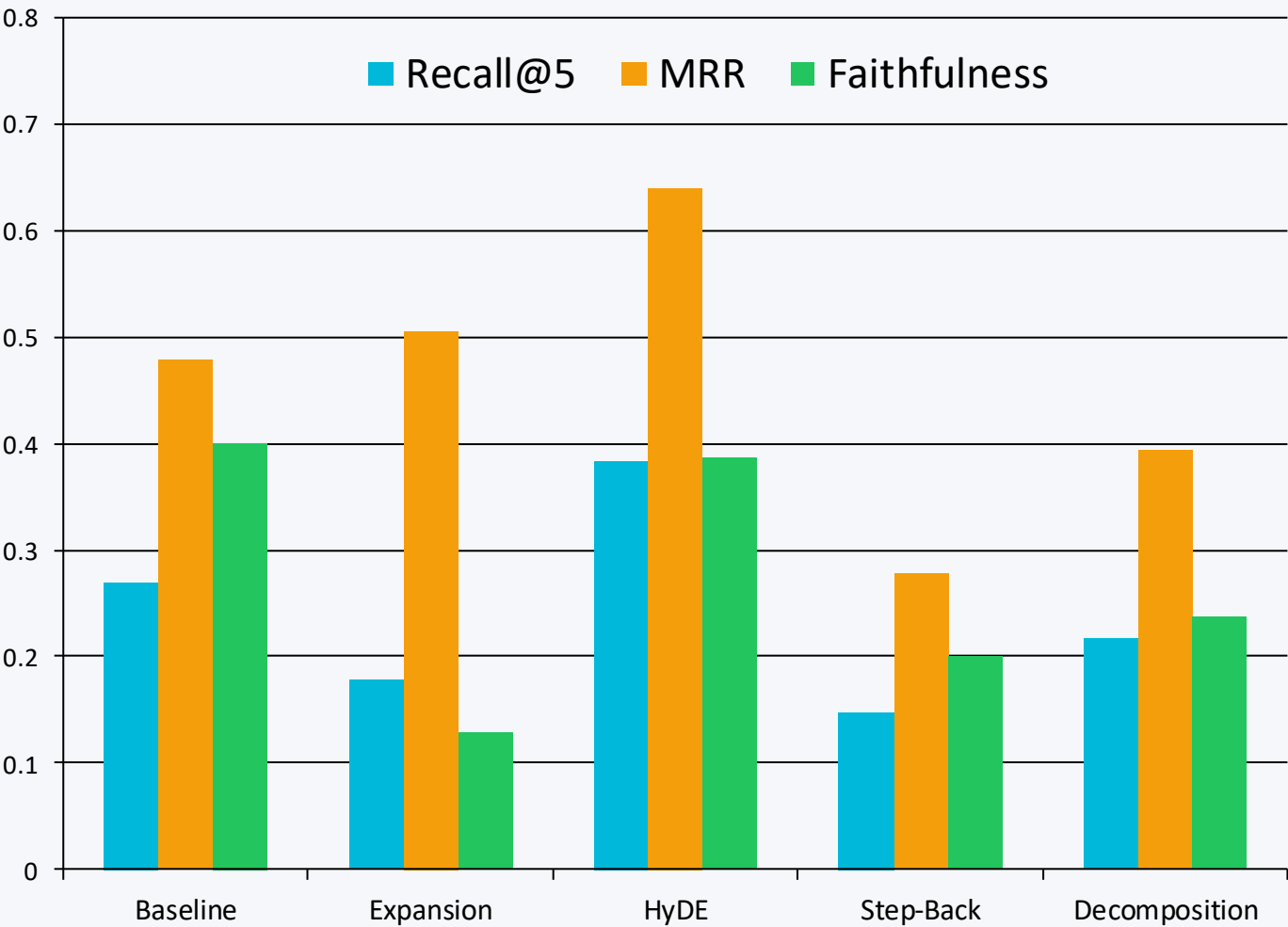
- something weird in my network traffic
- users complaining about being locked out

Specific:

- How does Pass-the-Hash work?
- How does DMARC protect against email spoofing?

6. Overall Benchmark Results

HyDE achieved the strongest mean retrieval performance across the full benchmark.



Best Overall

HyDE: Recall@5 = 0.383, MRR = 0.639

Strong Baseline

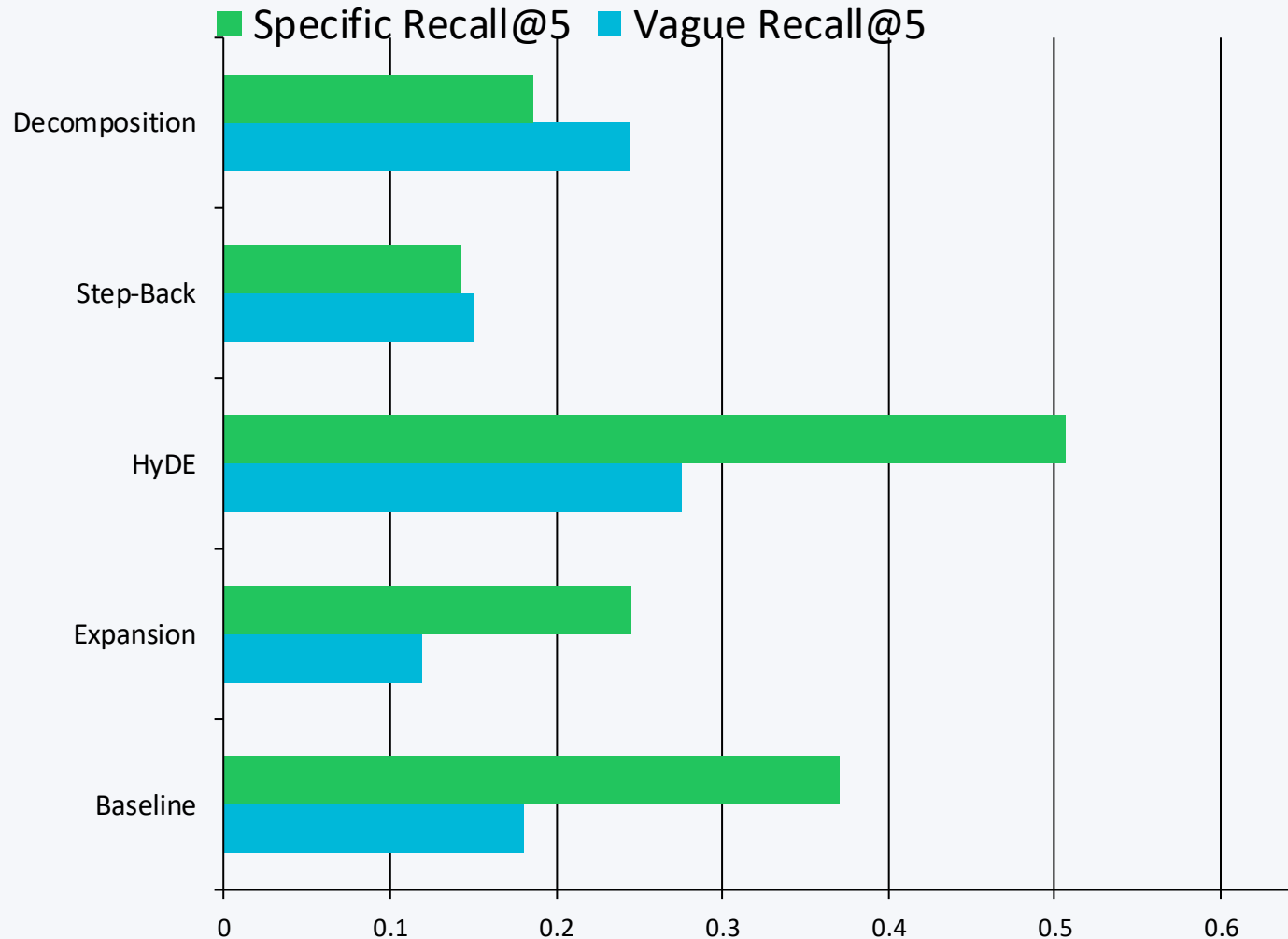
Baseline stayed competitive on faithfulness and specific technical queries.

Weakest Trend

Step-Back was usually too broad for security retrieval.

7. Vague vs Specific Query Insight

Query type matters. Reformulation is not universally better.



HyDE was the best-performing strategy for both vague and specific queries in the stored benchmark.

Baseline remained strong for already-specific questions like DMARC and ransomware techniques.

Expansion could help in some cases, but prompt drift made it unreliable.

This means security systems should route queries intelligently instead of applying one fixed reformulation method.

8. Demo Output - Example 1

Vague analyst query: users getting locked out randomly

Shows how the system compares baseline and reformulated answers.

```
#####
DEMO CASE: Vague Query – "users getting locked out randomly"
#####

BASELINE – Raw Query: "users getting locked out randomly"

Answer:

Based on the provided context, it appears that the issue of users getting locked out randomly could be related to brute force attacks on VNC libraries/implementations. The citations mention specific vulnerabilities such as "Hijacking VNC" and "macOS root VNC login without authentication", which suggest that unauthorized access attempts can lead to user lockouts.

It is possible that the issue of users getting locked out randomly is due to an attacker attempting to brute force their way into a VNC session, causing the account to be locked out after a certain number of failed login attempts. This would require further investigation and analysis to determine the root cause and implement appropriate mitigations to prevent such attacks.

However, without more specific information about the environment, such as the operating system, version of the VNC library, or any other relevant details, it is difficult to provide a more precise answer.

Recall@5=0.25 MRR=1.00 Faithfulness=0.20

-----
ENHANCED [EXPANSION]

Reformulated: "Are there any instances of brute-force attacks, session hijacking, or credential stuffing occurring on our system, potentially?"

Answer:

Based on the provided context, users getting locked out randomly could be a sign of brute forcing credentials. Adversaries may attempt to brute force access to valid accounts within a victim environment, leveraging knowledge gathered from other post-compromise behaviors such as OS Credential Dumping, Account Discovery, or Password Policy Discovery.

This behavior is consistent with the tactics, techniques, and procedures (TTPs) described in the context, where adversaries use various techniques to gather information about valid accounts and then attempt to brute force access to them. Therefore, if users are getting locked out randomly, it could be an indication of an adversary attempting to brute force credentials within the environment.
```

Key observation: reformulation can produce more security-aware explanations for vague symptoms.

9. Demo Output - Example 2

Summary of mean demo scores

SUMMARY – Mean Scores Across All Demo Queries			
Pipeline	Recall@5	MRR	Faithfulness
baseline	0.30	0.55	0.46 ← control
enhanced_expansion	0.30	0.38	0.47
enhanced_hyde	0.12	0.25	0.28
enhanced_stepback	0.25	0.33	0.55

KEY FINDING:
Reformulation helps most on vague queries.
HyDE and Query Expansion tend to outperform baseline on recall.
Specific queries sometimes perform equally well without reformulation.

subhodeepsarkar@MBA4-5GFF RAGDMS % █

What We Learned

The benchmark is not just about bigger answers. It is about retrieving better evidence first.

Why It Matters

In defensive security, wrong retrieval can mislead triage, investigation, and incident response.

Presentation Message

Reformulation helps selectively, not blindly. HyDE was the strongest approach in this experiment.

10. Advantages, Disadvantages, and Limitations

Advantages

- Improves retrieval for vague analyst-style questions
- Makes RAG more useful in security operations
- Runs fully locally with Ollama
- Supports multiple reformulation strategies
- Gives measurable comparison instead of guesswork

Disadvantages

- Reformulation can drift away from the original intent
- Some strategies hallucinate wrong terms or over-generalize
- More pipelines mean more latency and system complexity
- Weak retrieval cannot always be fixed by better prompting

Limitations

- Small benchmark of 15 queries
- Metrics are proxy metrics, not full human evaluation
- Dataset focused on ATT&CK, NVD, and CISA only
- Local lightweight model quality can limit reformulation performance

11. Applications and Future Scope

Applications

- SOC analyst assistants
- Incident triage copilots
- Threat hunting support systems
- Vulnerability knowledge assistants
- Security education and lab environments

Future Scope

- Larger benchmark with more annotated security queries
- Add system logs, SIEM alerts, and threat reports
- Build an adaptive router that selects the best pipeline automatically
- Use stronger local or hybrid models for reformulation

Main takeaway: the future is not one fixed reformulation method, but adaptive reformulation based on query type.

This project can be extended into a publishable larger-scale security retrieval study or production-ready analyst assistant.

Best final message for the audience: query reformulation helps when the query is weak, but it should be applied intelligently.

Project: defensive security RAG with query reformulation

Best overall method in our benchmark: HyDE

ENHANCED [HYDE]

Reformulated: "A user being locked out of their account due to excessive failed login attempts can be caused by a brute-force attack. T"

Answer:

Based on the provided context, it is possible that users are getting locked out randomly due to password guessing attacks. The text states that "Guessing passwords can be a risky option because it could cause numerous authentication failures and account lockouts, depending on the organization's login failure policies." This suggests that if an adversary uses brute force techniques to guess passwords, they may trigger multiple failed login attempts, leading to account lockouts.

Additionally, the context mentions that password guessing may or may not take into account the target's policies on password complexity or use policies that may lock accounts out after a number of failed attempts. This implies that if an adversary is using brute force techniques without considering these policies, they may inadvertently trigger account lockouts due to excessive failed login attempts.

Therefore, it is likely that users are getting locked out randomly due to password guessing attacks by adversaries using brute force techniques.

Recall@5=0.50 ↑ MRR=1.00 Faithfulness=0.83

ENHANCED [STEPBACK]

Reformulated: "Why are people's accounts being locked out unexpectedly?"

Answer:

Based on the provided context, it appears that users getting locked out randomly could be due to various reasons such as:

1. Password guessing attacks: As mentioned in the context, guessing passwords can cause numerous authentication failures and account lockouts, depending on the organization's login failure policies.
2. Malicious activities: Adversaries may delete, lock, or manipulate accounts to remove access, and subsequently log off and/or perform a system shutdown/reboot to set malicious changes into place.
3. Password complexity or use policies: The target's policies on password complexity or use policies that may lock accounts out after a number of failed attempts could also lead to users getting locked out randomly.

To investigate this issue, it would be essential to review the organization's login failure policies, check for any suspicious account activity, and verify if there have been any recent malicious activities. Additionally, reviewing password complexity and use policies could help identify if these are contributing factors to the random lockouts.

Thank You